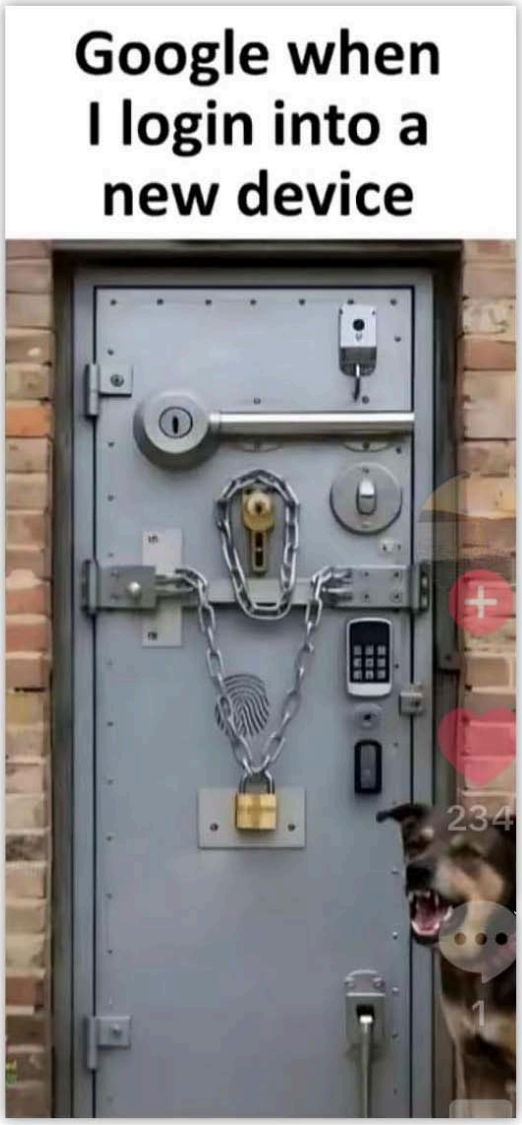
Security Now! #1055 - 12-09-25

React’s Perfect 10

This week on Security Now!

• France's VanityFair face a stiff fine over cookies. • GrapheneOS pulls out of France over coercion worries. • The EU adds to the pile-on over underage social media. • India mandates the tracking of all smartphones. • Apple says no. • India abandons its smartphone tracking mandate. • India requires all encrypted messaging to be SIM-tied. • Scattered Lapsus$ Hunters becomes “SLH”. • AI demand has driven RAM pricing sky high. • GRC's DNS Benchmark is finished and available. • Cisco may talk a good game, but they're still Cisco. • Browsers to ask users for local network access permission. • REACT: The worst remote code exploit in a LONG time.

Each year we jump through more hoops to increase our security. It’s become a lot. How much does all that really help?



Security News

"LES PUBLICATIONS CONDE NAST"

We've noted before that regulations that are not enforced will often be simply ignored. This is the equivalent of the annoying high school tough guy whose favorite retort is "Oh yeah? Well make me!" In the news is that the French edition of the VanityFair website at "vanityfair.fr" has had their bluff called to the tune of 750,000 euros.

The company LES PUBLICATIONS CONDE NAST publishes printed and online magazines, including the magazine Vanity Fair. Six years ago, way back in December 2019, the CNIL, France's data protection agency, received a public complaint from the association NOYB (which is the European Centre for Digital Rights) concerning the cookies placed on the devices of users visiting "vanityfair.fr". This was happening without any user notification or permission. After several investigations and discussions with the CNIL, Conde Nast received an order to comply in September 2021 and the proceedings were closed in July 2022.

A year later, in July and November 2023, then again in February 2025, the CNIL carried out further online investigations on the "vanityfair.fr" website and what do you imagine they found? Based on their findings, the restricted committee – the CNIL body responsible for issuing sanctions – considered that the company LES PUBLICATIONS CONDE NAST had failed to comply with the obligations of Article 82 of the French Data Protection Act, and imposed a fine of 750,000 euros. The amount of the fine is intended to take into account the fact that the company had already been issued with an order to comply, as well as the number of people affected and the various breaches of the rules protecting users with regard to cookies.

So, no one is going to shed a tear here. It wasn't as if the fine would or should come as any surprise. They were told what they needed to do and they apparently just blew off CNIL. I would imagine that someone is going to lose their job over this since this three quarters of a million euros fine could have been easily prevented. It's not as if Vanity Fair's visitors would care if they were to receive yet another cookie permission pop-up.

GrapheneOS leaves France

Meanwhile, the very nice Android alternative and API-compatible GrapheneOS recently posted on 'X' that it's leaving France due to a new French law that would mandate breaking its encryption. GrapheneOS posted:

> *We no longer have any active servers in France and are continuing the process of leaving OVH. [OVH is a French cloud hosting company.] France is no longer a safe country for open source privacy projects. They expect backdoors in encryption and for device access too. Secure devices and services are not going to be allowed. We don't feel safe using OVH for even a static website with servers in Canada/US via their Canada/US subsidiaries.*
>
> *We were likely going to release experimental Pixel 10 support very soon but that's getting disrupted. The attacks on our team with ongoing libel and harassment have escalated, raids on our chat rooms have escalated and more. It's rough right now and support is appreciated.*

It appears that GrapheneOS believes that they may have already been compromised because they also posted:

> *We'll be rotating our TLS keys and Let's Encrypt account keys pinned via accounturi. DNSSEC*

keys may also be rotated. Our backups are encrypted and can remain on OVH for now.

In the thread that following a more lengthy posting on 'X' which explained the details of their move, someone named "Lars" posted:

I am lead developer for a hosting company in Denmark. We do no have any backdoors or political influence in our company, and will never have. We host "everything" and we do not ask questions as long it's not illegal content. For normal FOSS projects we definitely do no ask questions!

GrapheneOS replied:

We appreciate it but unfortunately we'll likely have issues in Denmark too due to their push to outlaw encryption without backdoors. We'll hopefully still be able to operate in the EU in general but we want to avoid Chat Control supporting countries due to this experience.

GrapheneOS is not based in the US and is a non-profit open source project. [We're leaving France because] we don't trust that French law enforcement won't coerce OVH to do something after a judge signs off based on falsehoods. [We've been subject to] attacks by law enforcement on GrapheneOS including many false claims and also direct threats.

Reading between the lines, it sounds as though authorities with French law enforcement have demanded that GrapheneOS unlock some suspected criminals' handsets and Graphene has tried to explain that they do not have that capability. They wrote:

It's not possible for GrapheneOS to produce an update for French law enforcement to bypass brute force protection since it's implemented via the Secure Element (SE). The Secure Element also only accepts correctly signed firmware with a greater version AFTER the Owner user unlocks successfully.

We would have no legal obligation to do it even if we could, but it's not even possible. We have a list of our official hardware requirements including secure element throttling for disk encryption key derivation combined with insider attack resistance. And they aren't blaming Google for this design.

In Canada and the US, refusing to provide a PIN/password is protected as part of the right to avoid incriminating yourself. In France, they've criminalized this part of the right to remain silent. Since France is criminalized the refusal to provide a PIN, why do they need anything from us?

We don't know anything about what the French authorities believe might be on a criminal's confiscated GrapheneOS-based smartphone. But we certainly know why a suspect might choose not to share their password with the authorities. We talked about that tradeoff ages ago in the context of TrueCrypt's early whole disk encryption which was designed by cryptographers who knew how to completely and correctly protect a hard drive's data. Bad guys might have horribly incriminating material stored on a TrueCrypt'ed drive. So they would much rather face charges for not providing their password than provide the password and have authorities learn firsthand just how criminal they were.

I doubt that law enforcement authorities will ever accept being unable to unlock an encrypted device. They want in and they're sure they should have the right to see inside anything they choose. After all, they're the good guys, right? The EFF would beg to differ.

And now it's happening in the EU, too!
So here we are today, on the literal eve of the Australian law to ban use of social media – all social media – by anyone younger than 16. As we know, this effectively requires anyone who does wish to continue using any social media to prove that they are at least 16 years old. The onus has been placed on the social media providers to prevent the use of their systems by anyone younger than 16.

We're recording this on December 9th and tomorrow, December 10th, 2025, this country-wide law goes into effect... and saying that the whole world is watching is not an exaggeration. On Sunday, The New York Times piece was titled *"A Grand Social Media Experiment Begins in Australia"* with the tag: *"The country is trying to wean children under 16 off the likes of TikTok, Snapchat, YouTube and Instagram with a new law. The teenagers are skeptical."* Saturday the BBC's headline was *"Can you ban kids from social media? Australia is about to, but some teens are a step ahead."* I read the BBC piece. Kids are using still photos or VPNs. UNICEF Australia just has a piece titled "Social media ban" and they summarize their position writing: *"From 10 December 2025, anyone under 16 in Australia won't be able to keep or make accounts on social media apps like TikTok, Instagram, YouTube, Snapchat, X, Facebook and more. The rule doesn't punish young people or their families, instead, social media companies have to stop under-16s from having accounts or risk serious fines (up to about $50 million). The new law is meant to make things safer online, but UNICEF Australia believes the real fix should be improving social media safety, not just delaying access."* The Guardian headlined their piece *"'Everyone will miss the socialising – but it's also a relief': five young teens on Australia's social media ban"* The Guardian's piece started off: *"Australia's world-first social media ban for under-16s will begin in just a few days. Malaysia, Denmark and Norway are to follow suit and the European Union last week passed a resolution to adopt similar restrictions. As the world watches on, millions of Australian adolescents and their parents are wondering just what will actually change come 10 December."* NPR had a piece as well.

It's going to be interesting to see how all this pans out. The economic fine for repeated failure to enforce is $50 million Australian dollars, which is about $35 million US dollars. So that's not nothing. But there's also the reputational damage. It's clear that the ten affected social media platforms can not simply ignore this and do nothing. So they may simply adopt some lame measure that allows them to avoid penalties while kids gleefully work around and spoof the proof of age.

My feeling is that there was probably no way to avoid the present mess that the world is about to endure. Change is difficult even when everyone is pulling in the same direction and wants it. But change, when the platforms and their users all want to leave things as they are, and only some unseen government legislators and their regulators want to force change is bound to be a mess. I, of course, hope that some good technology will eventually step into the gap to provide privacy-respecting age verification, but we don't have that yet and we don't appear to even be close since the handset makers are strongly in the "we don't want this to be our problem" camp.

On the eve of this first country-wide event I wanted to also note that the EU is now making the same noises. And whereas Australia's human, non-kangaroo, population is about 27.5 million, the total population of the EU's current 27 member states is around 450.5 million. The European Parliament News recently posted a piece with the headline *"Children should be at least 16 to access social media, say Members of the European Parliament (MEPs)."* However things may be

better in the EU from a privacy and accuracy standpoint.

A vote was held two weeks ago, Wednesday, where the Members of the European Parliament voted to adopt a non-legislative report by 483 votes in favour, 92 against and with 86 abstentions. The report and their votes expressed deep concern over the physical and mental health risks minors face online and called for stronger protection against the manipulative strategies that can increase addiction and that are detrimental to children's ability to concentrate and engage healthily with online content. Here's the part that caught my eye in the EU's reporting. They wrote:

> *Expressing support for the Commission's work to develop an EU age verification app and the European digital identity (eID) wallet, MEPs insist that age assurance systems must be accurate and preserve minors' privacy. Such systems do not relieve platforms of their responsibility to ensure their products are safe and age-appropriate by design, they add.*

The idea that the Commission would be pressing for an EU age verification app is all good news. Given some means for establishing an individual's date of birth – which may be the European digital identity – that date can easily be protected while simple assertions of "old than x" are trivial to generate with total security and anonymity.

So my takeaway here is that, yes, we're about to descend into some chaotic times. But given the kicking and screaming by the platforms and their users, this was inevitable. The right people understand the concepts of accurate privacy-preserving solutions and they know this is possible. So I have no doubt that the world will eventually obtain a good solution.

India's bold (and doomed) plan to track all smartphone usage

Continuing on the topic of government legislators seemingly losing their multi-decade shyness toward legislating our use of personal technology, comes the news that the government of India intends to verify and record every smartphone in use by their citizens. That was essentially TechCrunch's headline, under which they wrote:

> *The Indian government is widening the scope of its anti-theft and cybersecurity initiative to cover both new and used smartphones, an effort aimed at curbing device theft and online fraud but a move that is also raising fresh privacy concerns.*
>
> *As part of the expansion, the Indian telecom ministry is requiring companies that buy or trade used phones to verify every device through a central database of IMEI numbers. This comes in addition to a recent directive ordering smartphone manufacturers to preinstall the government's Sanchar Saathi app on all new handsets and push it onto existing devices through a software update.*

Yes, you heard that correctly. India now requires all handset makers to pre-install a state mandated app and also to retro-install the app into all existing devices. TechCrunch continues:

> *Reuters first reported the news on Monday, which was later confirmed by the ministry in a public statement. Launched in 2023, the Sanchar Saathi portal allows users to block or trace lost and stolen phones. The system has blocked more than 4.2 million devices and traced 2.6 million more devices, per government data. The system expanded earlier this year with the release of a dedicated Sanchar Saathi app in January, which the government says helped*

recover more than 700,000 phones, including 50,000 in October alone.

Wow. I guess India has a very serious smartphone theft problem.

The Sanchar Saathi app has since gained broad adoption. The app has been downloaded nearly 15 million times and saw more than 3 million monthly active users in November — up more than 600% from its launch month, according to marketing intelligence firm Sensor Tower. Web traffic to Sanchar Saathi has also surged, with monthly unique visitors rising by more than 49% year-over-year, per Sensor Tower data shared with TechCrunch.

So up to this point it appears that the choice to have one's smartphone protected with this tracing and recovery app has been the users'. But TechCrunch writes:

The government's order to preinstall Sanchar Saathi has already drawn significant backlash from privacy advocates, civil society groups, and opposition parties. Critics argue the move expands state visibility into personal devices without adequate safeguards. The Indian government, however, says the mandate is intended to address rising cases of cybercrime, such as IMEI duplication, device cloning, fraud in the secondhand smartphone market, and identity theft scams.

Responding to the controversy, the Indian telecommunications minister said Tuesday that Sanchar Saathi is "a completely voluntary and democratic system" and that users can delete the app if they do not wish to use it. The directive reviewed by TechCrunch — and circulating on social media on Monday — instructs manufacturers to ensure the preinstalled app is "readily visible and accessible to end users at the time of first use or device setup" and that "its functionalities are not disabled or restricted," raising questions about whether the app is truly optional in practice.

India's deputy telecom minister said in media interviews that most major manufacturers were included in the government's working group on the initiative, though Apple did not participate.

Alongside pushing the Sanchar Saathi app, two people familiar with the matter told TechCrunch that the telecom ministry is piloting an application program interface — or API — that would allow re-commerce and trade-in platforms to upload customer identities and device details directly to the government. The move would mark a significant step toward creating a nationwide record of smartphones in circulation.

India's used-smartphone segment is expanding rapidly as rising prices of new devices and longer replacement cycles push more consumers toward cheaper alternatives. India became the world's third-largest market for secondhand smartphones in 2024.

But as much as 85% of the secondhand phone sector remains unorganized, meaning most transactions occur through informal channels and through brick-and-mortar stores. The government's move covers only formal re-commerce and trade-in platforms, leaving much of the broader used-device market outside the scope of the current measures.

While announcing the preinstallation of its app, the Indian government said the move would help enable "easy reporting of suspected misuse of telecom resources." Privacy advocates say that the growing data flows could give authorities unprecedented visibility into device ownership — raising concerns over how the information could be used or misused.

The head of programs and partnerships of Toronto-based nonprofit policy lab Tech Global Institute, told TechCrunch: "It's a troubling move to begin with. You're essentially looking at the potential for every single device being 'databased' in some form. And then what uses their database can be put to it at a later date, we don't know."
The Indian government has not yet detailed how the collected data will be stored, who will have access to it, or what safeguards will apply as the system expands. Digital rights groups say the sheer scale of India's smartphone base — estimated at some 700 million devices — means even administrative changes can have outsized consequences, potentially setting precedents that other governments may study or replicate.

"While the intent behind a unified platform may be protection, mandating a single government-controlled application risks stifling innovation particularly from private players and startups who have historically driven secure, scalable digital solutions," said the director of the New Delhi-based technology think tank Esya Centre.

"If the government intends to build such systems, they must be backed by independent audits, strong data governance safeguards, and transparent accountability measures. Otherwise, the model not only puts user privacy at stake, but also removes fair opportunity for the ecosystem to contribute and innovate." The planned API also raises concerns for re-commerce firms, which could face liability if sensitive customer information is mishandled.

The Indian telecom ministry did not respond to TechCrunch's request for comment.

While the Sanchar Saathi app is visible on a user's phone, the broader system it connects to operates largely out of sight. The permissions, data flows, and back-end changes, including the planned API integration, may be buried in long terms-and-conditions documents that most people never read, he said. As a result, users may have little practical understanding of what information is being collected, how it is shared, or the extent of the system's reach.

"You can't go about restricting cybercrimes and device thefts in such a disproportionate and heavy-handed way. The government is basically saying that, look, you need to put my app on every device that is sold, on every existing device, you have to install it, and in anything that's being resold as well."

We know about the tyranny of the default. If the app is pre- and post-installed a great many more will be in use. Most people will not remove it. And it's not completely clear whether removal will be an option, since the Indian government's intention looks to be more aimed at assuring that all smartphones participate. And, of course, one wonders what Apple would think about such a mandate. On the other hand, India is now producing Apple's smartphones so Apple might lack some leverage they might have otherwise enjoyed.

Apple does, indeed, say "No".
As I kept digging I discovered that, to no one's surprise, Apple does not plan to abide by India's order. The India Times headline was: *"Apple to resist DOT order to preload state-run Sanchar Saathi app as political outcry builds"* And we get some more information about disabling or removing that makes more sense. The India Times writes:

Apple does not plan to comply with a mandate to preload its smartphones with a state-owned cyber safety app and will convey its concerns to New Delhi, three sources familiar with the

matter said, after the government's move sparked surveillance concerns. The Indian government has confidentially ordered companies including Apple, Samsung and Xiaomi to preload their phones with an app called Sanchar Saathi, or Communication Partner, within 90 days. The app is intended to track stolen phones, block them and prevent them from being misused.

Whoa! "Block them and prevent them from being misused" ?? – meaning that the government app can prevent a phone from operating? I didn't pick up on that in the previous reporting. That's what's known in the business as "a biggie!" That suggests that this "Communication Partner" app would have the ability to shut down a phone. If that's the case it's no wonder that Apple is saying "not thanks." The reporting continues:

Reuters was first to report on Monday that the government also wants manufacturers to ensure that the app is not disabled. Also, for any devices already in the supply chain, manufacturers should push the app to phones via software updates.

The telecom ministry confirmed the move later, describing it as a security measure to combat "serious endangerment" of cyber security. But Prime Minister Modi's political opponents and privacy advocates criticized the move, saying it is a way for the government to gain access to India's 730 million smartphones.

Two of the industry sources who are familiar with Apple's concerns said that Apple does not plan to comply with the directive and will tell the government it does not follow such mandates anywhere in the world as they raise a host of privacy and security issues for the company's iOS ecosystem. They declined to be named publicly as Apple's strategy is private.

The first source said: "It's not only like taking a sledgehammer, this is like a double-barrel gun." For its part, Apple and the telecom ministry did not respond to requests for comment. The app order comes as Apple is locked in a court fight with an Indian watchdog over the nation's antitrust penalty law. Apple has said it risks facing a fine of up to $38 billion in a case.

The second source said Apple does not plan to go to court or take a public stand, but it will tell the government it cannot follow the order because of security vulnerabilities. The person said: "Apple can't do this. Period."

Other brands including Samsung are reviewing the order, said a fourth industry source who is familiar with the matter. Samsung did not respond to Reuters queries. Sources have said the government moved forward with the order without industry consultation.

While Apple tightly controls its App Store and proprietary iOS software - which are crucial to its $100-billion-per-year services business - Google's Android is open-sourced, allowing manufacturers like Samsung and Xiaomi greater leeway to modify their software.

India's main opposition Congress Party has called for a rollback of the mandate posting on 'X' that "Big Brother cannot watch us." The government's press release said the app can help tackle incidents of duplicated or spoofed IMEI numbers, which enable scams and network misuse. The telecom ministry said in a statement late on Monday: "India has big second-hand mobile device market. Cases have also been observed where stolen or blacklisted devices are being re-sold."

India abandons mandatory cyber app requirement

And then, in a late update, India backpeddled on their requirement. The press release from the Ministry of Communications proclaims across its top: "Government removes mandatory pre-installation of Sanchar Saathi App". It turns out that the government changed its mind two days after the announcement following extensive public criticism of veiled surveillance. I decided to keep the original reporting because it's still useful to understand what's in the air. But India may not be done meddling in the operation of its citizens communications:

Why your WhatsApp Web may now log out every six hours

The India Times also had a headline *"Why your WhatsApp Web may now log out every six hours"* India's DoT, Department of Telecommunications has been working overtime. Get a load of this one. The India Times writes:

> *Due to a new directive from the Department of Telecommunications (DoT), WhatsApp Web will automatically log out users every six hours.*
>
> *Under the new rule, the DoT requires messaging apps, including WhatsApp, Telegram, and Signal, to implement "SIM binding". In other words, linking of the users of services to the SIM card used for registration via its IMSI identifier. If the original SIM is not present, access to these apps will be blocked 90 days from the directive's issuance.*

Well. Good luck telling Signal's Meredith Whittaker that you're requiring Signal to bind to specific SIM cards. Signal has historically been bound to a user's phone, but there's no way that Signal would be modifying their app if it meant the slightest reduction in the privacy of their users. And if this move did **not** represent some enhanced form of government control, then why would India be mandating this change? And there's more. The India Times continues:

> *Under the same directive, web versions of these applications will log their users out periodically, no later than every six hours, and force a re-authentication via a QR code scan. A user logs in to WhatsApp Web through a browser, by scanning the QR code through the phone application. According to the authorities, this is to curb cyber fraud by preventing misuse of apps without active SIMs, often by scammers operating from abroad. Platforms are required to comply within 90 days and submit reports within four months, potentially by around February next year. The rules will apply to WhatsApp, Telegram, Signal, Snapchat, and other OTT (over the top) messaging platforms operating in India.*
>
> *Users are likely to face workflow disruptions, especially multi-device professionals and travellers and small businesses that rely on shared devices. WhatsApp has 500 million Indian users and a major chunk of its business users are also in the country.*
>
> *One user wrote on X: "Sim binding rule shall be a major disruption for professionals and businesses using web accounts of WhatsApp etc. It won't eliminate the fraud completely, as Sim Cloning / Sim Spoofing will still work."*
>
> *While a section of the tech industry believes that the DoT might have breached its regulatory mandate, officials clarified that the directions issued to the apps are within the purview of telecom cyber security rules. An official told The India Times: "It is only for the entities that use telecommunication identifiers like a mobile number for their services. If they don't want to do the SIM binding, they should not use the mobile number as an identifier."*

Industry representatives also questioned the effectiveness of SIM binding in curbing fraud originating outside India, noting that scam operators can still obtain Indian SIMs through mules or remote devices, while a significant volume of fraud originates within the country.

We appear to be entering a period where government legislators are feeling increasingly empowered to dictate the operation of the personal communications devices operating within their jurisdictions. And I've found no indication yet that India will be backing down from this one.

Scattered Lapsus$ Hunters -becomes-> "SLH"

A random observation that I'm beginning to see the infamous *"Scattered Lapsus$ Hunters"* group being referred to by the abbreviation *"SLH"*. I don't know if it will catch on, but they have been so much in the news that the security industry appears to feel that they've become *"abbreviation worthy."* The news blurb that caught my eye, referring to **SLH**, was a note that the group may have shifted their focus away from Salesforce and over to ZenDesk. They appear to be enamored of the SaaS – Software as a Service exploitation model. There was a lack of clear attribution for some very recent ZenDesk-related attacks, so time will tell.

RAM pricing is out of control

I suppose we should have seen this coming. This next bit of news is not security related, but it's tangentially AI related and I thought that our computer-centric listeners would find it interesting. The short blurb that caught my attention read:

Micron exits consumer RAM market: *American hardware vendor Micron will leave the consumer RAM market and discontinue its Crucial brand. The move comes as the AI boom has led to an explosion in prices for RAM and SSDs as AI companies build data-guzzling data centers and have swallowed almost the entire market output for the next few years.*

That led me to look for some additional detail which I thought our podcast listeners would appreciate. I found a nice piece over on The Verge, whose headline was *"RAM prices are so out of control that stores are selling it like lobster."* They wrote:

Michael Crider's headline at PCWorld today perfectly captures how ridiculous the PC memory shortage has become: stores like the San Francisco Bay Area's Central Computers are beginning to sell RAM at market prices, like you'd pay for the catch-of-the-day at a seafood restaurant. A message posted in the store's display case reads: "Costs are fluctuating daily as manufacturers and distributors adjust to limited supply and high demand. Because of this, we cannot display fixed prices at this time." Micro Center is apparently doing the same: "Due to market volatility, we ask that you please see a Sales Associate for pricing."

It's hard to overstate just how quickly the RAM crunch is changing the affordability of computers — and it might soon impact other realms as well, as everything from game consoles to smartphones require RAM to function.

Three months ago yesterday, I bought 32GB of memory for my gaming PC and the price of that exact kit has more than tripled since then. It now costs $300 more. ($440 vs. $130, in case you're curious; a more common version of the same kit went from $105 to $400.) Some prices have doubled since October, and while you can still find some 32GB kits for as low as $230, a 64GB DDR5 kit can easily run you $700, $800, even $900. Some high-profile product

launches might be impacted by the price of memory. Valve pointed to the RAM crunch as one reason it couldn't promise a specific price for its Steam Machine just yet.

Just as out-of-control GPU prices from earlier this year have finally settled down, runaway memory prices might make them shoot back up again. Every graphics card requires gobs of VRAM, more is better, and word is that Nvidia and AMD are preparing to raise prices to compensate for the crunch. Digital Foundry is recommending you buy a GPU at or below MSRP while you still can, one with 10GB or more of VRAM.

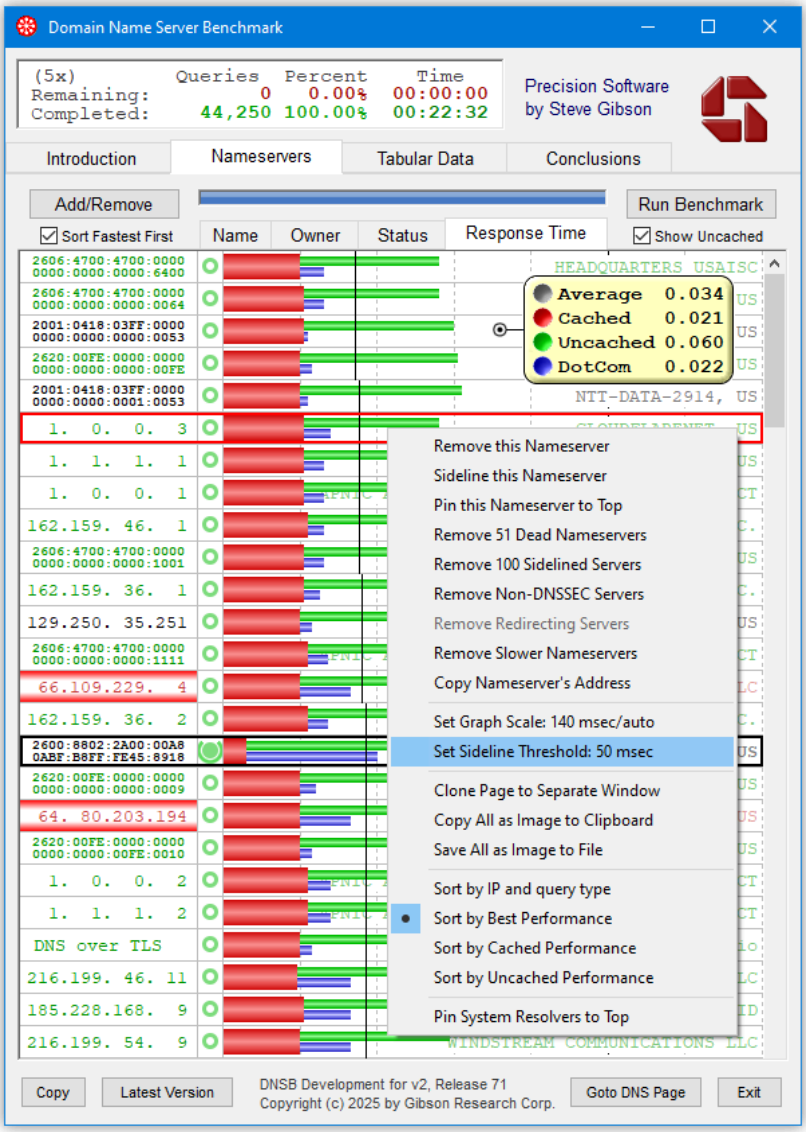
Microsoft may have to raise Xbox prices yet again to compensate, but Sony has stockpiled enough RAM for the PS5 to last some number of months. Epic's CEO Tim Sweeney says it may take years for high-end gaming to recover from the RAM crunch, because of AI. He says "factories are diverting leading edge DRAM capacity to meet AI needs where data centers are bidding far higher than consumer device makers."

I noted another piece in the news yesterday that said 200 environmental groups (I didn't realize there ***were*** 200 environmental groups!) are demanding (love that choice of words) a halt to the construction of new US data centers. I guess just on principle. First of all, good luck with that. That might have stood some chance if a bleeding heart democrat were the country's current executive. But Trump recently again declared that global warming was a hoax and that wind turbines cause cancer. So I would be highly skeptical that any number of environmental groups are going to get much traction in the current Washington climate.

But what's interesting from a technology standpoint is that it does appear that the desire to concentrate an unprecedented amount of computational capability within a comparatively small area is truly causing trouble. If nothing else, just getting that much electrical power service to a single location is not something the existing power grid is set up to deliver. And when you step back to think about it, the only reason to want that much computation in such a small space must be economies of scale. What I mean by that is that what's being built is not a single humongous brain. It's a very large number of individual small brains. And they don't actually need to all be under the same roof, or even in the same state for that matter. It's just more convenient and cost-effective if they're all grouped together. That way they can all share staff, utilities, walls, security, cooling, parking lot, and so on. This suggests that a reasonable compromise might be to limit the total size of individual AI data centers, have more of them and spread them around more. That said, I certainly get the raw coolness factor of having a massive AI data center. Now... if only AI actually made money and could pay for itself.

Okay… it's announcement time!

GRC's DNS Benchmark



I am extremely pleased and proud to announce that after almost exactly one year, GRC's first new commercial product in several decades has been finished and is now available for purchase and download from GRC's website.

Everyone listening knows that this is the hugely improved commercial version of GRC's most popular ever freeware, our DNS Benchmark. My original plan was to create a pair of commercial improvements to be called "Plus" and "Pro". But as the final new base edition kept evolving, there was less and less benefit to be had from a "Pro" edition. So I finally decided to give the base edition many of the features that had been slated for Pro, to have a single new DNS Benchmark called version 2, and to offer it with a lifetime one-time purchase license which entitles its owner to the entire future of the product, no matter what that may be, without ever paying anything more... for $9.95.

Looking back on the past year, that seems like a long time. But as I have mentioned previously, the original code had IPv4 so deeply designed into it back in 2008 that I actually had many false starts and retrenchments as I kept trying to find a way to add support for IPv6 and the two TLS DNS technologies DoH and DoT. I finally figured out how to do that and all four protocols now coexist perfectly.

The single biggest change to the Benchmarking since version 1 was released 16 years ago is that the Internet has changed so that uncached DNS lookups, rather than only cached lookups, have become important. 16 years ago, most of a webpage's content was being served by the domain being visited. That meant that once the IP for its domain name was known, the page could be displayed with many additional fetches from the same domain and IP.

But these past 16 years have seen that dramatically change. When talking about things like uBlock Origin and other content-control utilities, we've noted that the content of today's websites are being pulled from scores of disparate sources with pages pieced together from far and wide all across the Internet. This has significantly increased the importance of DNS lookups that are ***not*** cached... where other resolvers need to be consulted.

Because of the way things were back in 2008, version 1 of the DNS Benchmark used a strictly hierarchical resolver ranking algorithm. The first sort order was cached performance. It completely dominated all resolver ranking. Cached performance was the amount of time a resolver would need to reply to a query for a domain's IP that it already knew and had cached locally. It turns out that Internet transit times so much dominate this, that cached performance is essentially equal to the time required to "ping" the resolver. While that might not seem like something worth knowing, it turns out that DNS performance is all about connectivity. What you want is a very good resolver that's also very close.

The problem was, that's all that version 1 of the Benchmark took into consideration. If a resolver close by could beat out other resolvers, version 1 gave it the highest ranking. Only in the case of a tie in cached performance – within 1 millisecond of resolution – would uncached lookup performance be considered as the second sort key. The problem with that was that a resolver might reply to cached queries in 5 milliseconds but take ten times as long – 50 milliseconds – to perform a lookup of something it didn't already know. Whereas another resolver might take 6 milliseconds to reply to a cached query but only 10 milliseconds to look up something it didn't already know. I'd much rather be using that second resolver, since that first resolver's extremely lengthy uncached lookup time is going to have a significant effect on the speed of today's highly distributed webpage assembly.

And something else happened during the intervening 16 years. Back in 2008, no one had local border NAT routers that were also caching resolvers. We had NAT back then, but those early NAT routers were not doing DNS lookups for their LAN clients. When our PCs used DHCP to obtain their IPs they also received the IP addresses of the ISP's supplied DNS resolvers. These days, many consumer grade NAT routers **are** running their own DNS, and our PCs receive the router's IP for all DNS resolutions.

This matters because the original version of the DNS Benchmark would be seriously over-impressed by the performance of that local caching DNS resolver. How could any possible remote DNS resolver – no matter how fast it might be – possibly complete with the caching resolver sitting right there next to the user on their own LAN? Try pinging your LAN's gateway and see how quickly it replies. And since the original benchmark's ranking strategy was to prize caching performance above all else, the LAN's caching resolver would always be placed at the top of the list, even if its uncached actual domain name lookup performance might be truly atrocious.

So what does the new version 2 of the DNS Benchmark do? It simply takes the **average** of all three types of DNS queries: cached, uncached, and dotcom resolver. Version 2 has four sorting options. The original cached-first sort is still there for anyone who wants it for some reason, but the new default is just called "Best" performance and that's the default.

What we found during the past year of testing is that, as I noted earlier, what matters most is the connectivity of DNS resolvers. IP packet roundtrip transit times are where the vast majority of time is spent. This means that a popular CDN's big fast resolver which is nearby on the Internet can generally outperform someone's own DNS resolver that takes a long time to lookup any IP it doesn't already know.

As can be seen in the screen shot of the v2 DNS Benchmark on page 13, the performance bar

chart still shows the original three bars, one for each query type. But it also shows a new thin black line to mark the average of those three, and resolvers are now ranked according to **that** line. I suspect that many owners of the version 2 benchmark will be able to significantly improve their network's DNS lookup performance by studying the results of this modernized ranking.

And, of course, for the first time we can gauge the relative performance of IPv6 resolvers versus IPv4 as well as the relative performance of the newer securely authenticated and snoop-proof encrypted DoH and DoT resolvers. DoT can be used natively by Android and DoH can be used natively by all of our web browsers. There's no longer any reason for us to be vulnerable to ISPs profiling us by our DNS lookups.

The question then becomes, which of the hundreds of alternatives performs best for you? The reason there's no single right answer for everyone is that, as we have found, it's all about packet transit time, and that's all about location. Or as they say about retail: "It's location, location, location." The new benchmark contains an updated built-in list of 126 possible IPv4 resolvers, 43 IPv6 resolvers, 81 DoH resolvers and 60 DoT resolvers. And on top of that, the Benchmark's built-in custom list builder is also able to quickly scan through 4,909 possibly-faster resolvers.

Anyway, everyone gets the idea. I'm very proud of this latest work and I owe a debt of gratitude to the wonderful gang over in GRC's DNS development newsgroup. Many of them offered great ideas, observations and suggestions that wound up improving the result measurably. We all get the benefit of their contributions. This GRC utility is offered for $9.95, a one-time fee which entitles its owner not only to use it forever, but also to any and all updates or upgrades, no matter what they may be throughout the rest of the product's life. That's a model that I think works to everyone's benefit.

Listener Feedback

Stefano from Sunny Italy

*Hi Steve. I feel there's a specific aspect which has been left out in this whole Cisco improvement of resilience see-the-light moment: as a long time network engineer I always found infuriating the hoops that I have to jump through in order to download a patched firmware image from any of the biggest vendors, ***especially*** Cisco. Them crying about the fact that there's so many unpatched devices still exposed is peak irony and is partially on them.*

*If I buy some piece of hardware I expect you, the vendor, to support it and patch it for a reasonable amount of time. But within that reasonable time frame I ***must*** be able to easily access updates without them being locked out behind "support contracts" or similar immoral (in my eyes) double dipping. Device lifecycle management is perhaps the hardest part of this job: the strings of the purse are never in our hands so it's not our call... only the consequences are on us!*

I'm sure many more fellow engineers have been in my same situation, perhaps after changing jobs and ending up in a barely maintained infrastructure or simply having to wait for the next round of funding in order to swap out some old lemon.

Quoting Cisco's Anthony Grieco: "This is further amplified by the fact that many organizations have not updated and maintained their network infrastructure missing opportunities to fix known vulnerabilities [...]" Then stop preventing me from doing so Anthony!

The Steve from sunny Italy

Stefano's note reminded me that back when I was running a bonded pair of T1 trunks to my home here and was using a Cisco router to do the work, Cisco was not wonderful to deal with. I had assumed that they were better now, but from what Stefano indicated, perhaps not.

Blair Learn

*Hi Steve, I ran across an item I don't believe you've covered yet. Google recently rolled out (in Chrome 142) something they're calling "Local Network Access." The gist of it is that if you have a public web site, such as https://example.com, it has the potential to host malicious JavaScript code which attempts to access resources on your **local** network. For example, the router admin interface on 192.168.0.1. (The technique seems similar to the issue you described a month or two back with adware setting up a server on a phone's localhost address to be used by the adware vendor's ad code for tracking purposes.)*

Local Network Access is a new permission in the browser. The user is prompted to allow access to devices on the local network, and if permission is denied, then code on example.com is prohibited from contacting resources in the myriad local networks.

You might ask, "Why would you ever want to allow such a thing in the first place?" My use case was a development website hosted by an external vendor, with a JavaScript application contacting a test version of an API that was hosted on a server which is only accessible via VPN. Probably not something most home users are going to encounter, but I have to imagine other enterprise developers would.

Google has a blog post about it at https://developer.chrome.com/blog/local-network-access and the spec can be found at be found at https://wicg.github.io/local-network-access/

As always, I look forward to the next episode of Security Now. SpinRite licensee, Club Twit member, and general-purpose geek. /Blair

This has been a significant and growing problem forever. There was a point, it might have been during the pre-release of IE 11, where Microsoft flirted with flatly denying their browser's access to the localhost address 127.0.0.1 or the local LAN. This came up at the time because I was working on SQRL and one of the ways it robustly prevented interception was by allowing the user's local browser to connect to a little web server in SQRL. This gave the browser a private connection to the authenticator which it could use to cut out any possible man-in-the-middle. Passkeys implements the same protection with users' smartphones using Bluetooth to create a local link to the web browser that no remote attacker can possibly intercept.

In the case of Microsoft and IE 11 and the localhost IP, they came to their senses and realized that there were far too many valid use cases where a web developer, for example, might be running a local server or services on their local machine and needed to be able to access it with their browser. Until now, this has been an unsolved problem in need of a comprehensive solution. Our browsers are no longer just passive content displays. Technologies such as JavaScript and WebAssembly have turned them into effective application platforms.

Just to be completely clear about the nature of the problem, from the perspective of any web browser sitting on a private local area network, the web browser has network visibility into two networks. It can obviously "see" and access the global public Internet because it's able to access and obtain remote content. But the browser can also just as easily "see" its own local area network. We know this, because, for example, LAN routers are managed by aiming a browser at the LAN router's gateway IP which is typically 192.168.0.1 or .1.1 or similar.

The problem is that a user might visit a malicious remote website which causes their web browser to download and run some malicious JavaScript or WebAssembly code. Now, that the code is running inside the user's browser, the Trojan horse has essentially been invited into the house. Unless something is done, that malicious code that's now running in the user's web browser has the same access to their LAN that they do. It can reach out and log into their LAN router, scan their network for any other juicy targets, or get up to whatever mischief it might wish to. When you stop to think about it, it's somewhat amazing that this big loophole has been closed long ago. The good news is, it is finally going to happen.

The W3C's specification for this new feature explains its entire purpose and scope, writing:

> *Although RFC1918 has specified a distinction between "private" and "public" internet addresses for over two decades, user agents have not made much progress at segregating one from the other. Websites on the public internet can make requests to local devices and servers, which enable a number of malicious behaviors, including attacks on users' routers [and they list some example].*
>
> *Local Network Access aims to prevent these undesired requests to insecure devices on the local network. This is achieved by deprecating direct access to local IP addresses from public websites, and requiring that the user grants permission to the initiating website to make connections to their local network.*
>
> *The overarching goal is to prevent the user agent from inadvertently enabling attacks on devices running on a user's local intranet, or services running on the user's machine directly. For example, we wish to mitigate attacks on:*
>
> *Users' routers or on software running a web interface on a user's loopback address. For better or worse, this is becoming a common deployment mechanism for all manner of applications, and often assumes protections that simply don't exist.*
>
> *There should be a well-lit path to allow these requests when the user is both expecting and explicitly allowing the local network access requests to occur. For example, a user logged in to plex.tv may want to allow the site to connect to their local media server to directly load media content over the local network instead of routing through remote servers.*

The specification then further clarifies the intent with a couple of examples:

> *Alice is at home on her laptop browsing the internet. She has a printer on her local network built by Acme Printing Company that is running a simple HTTP server. Alice is having a problem with the printer not properly functioning. So Alice goes to Acme Printing Company's web site to help diagnose the problem. Acme Printing Company's web site tells Alice that it can connect to the printer to examine its diagnostic output. Alice's browser asks Alice to allow https://support.acmeprintingcompany.com to connect to local devices on her network.*

Since this is something Alice wants and is expecting, she grants explicit permission for that website to connect to local devices on her network. Acme Printing Company then connects to her local printer's diagnostic output through Alice's web browser, and tells Alice that a part is malfunctioning on the printer and needs to be replaced.

The W3C also provides an alternative case example:

Alice continues browsing online to find the best price for the replacement part on her printer. While looking at a general tech support forum, she suddenly gets a permission request in her browser for https://printersupport.evil.com to connect to local devices on her local network. Being suspicious of why https://printersupport.evil.com would need to connect to local devices, she denies the permission request.

And this, of course, presents us with a problem because while, yes it's 100% true that for the first time ever the user sitting in front of their web browser will be required to proactively allow some remote website to access their network — and that represents a nice step forward in security **capability** — the trouble is, it's still just a capability because we've also just saddled users with the new responsibility of determining what's benign and what's malicious. How is anyone really going to know? If we've learned anything, it's that many users are unable to reliably tell the difference. And it's really not their fault, since we've also seen that bad guys can be highly motivated and very inventive. We know that the so-very-human user remains the weakest link in the security chain.

So now Chrome, and presumably other browsers, will be popping up notifications when something you're doing requires a remote site to have access to your local network. Allowing that to happen without any notification, as we've been doing until now, is certainly not safe. But no one should imagine that if any really juicy targets appear on user networks, the bad guys aren't going to cook up some very reasonable appearing reason why users should give their remote web domains access to the user's local network devices.

I'm sure that Google's Chrome guys, who were the driving force behind this W3C spec, are only presenting this imperfect solution, with full knowledge of its imperfection, because it was the best solution they could come up with. The mantra must have been "yeah, but it's better than nothing." And I agree.

React's Perfect 10

"A Perfect 10" RCE discovered in open source REACT servers.
By this time, from everything we've seen and shared on this podcast through the years, we can probably all define what a worst-case vulnerability looks like. It would affect any popular, widely present Internet-facing server. It would not require the remote attacker to first be in any way "authenticated" on that server. It would allow said attacker to remotely supply whatever code they would wish any such server to execute on their behalf. And the attack would have a low-complexity so that no rocket science is needed. Taken together, in the parlance of the day, we would term this a critical, unauthenticated, low-complexity remote code execution vulnerability. A shorter, though less descriptive summary, might also be a "CVSS 10.0".

The headline given to Dan Goodin's reporting of just such a vulnerability last Wednesday in ArsTechnica was: *"Admins and defenders gird themselves against **maximum-severity** server vuln"* with the subhead: *"Open source React executes malicious code with malformed HTML—no authentication needed."* There's a lot to cover here, so let's begin with Dan's description in ArsTechnica. Dan Writes:

> *Security defenders are girding themselves in response to the disclosure of a maximum-severity vulnerability disclosed Wednesday in React Server, an open-source package that's widely used by websites and in cloud environments. The vulnerability is easy to exploit and allows hackers to execute malicious code on servers that run it. Exploit code is now publicly available.*
>
> *React is embedded into web apps running on servers so that remote devices render JavaScript and content more quickly with fewer resources required. React is used by an estimated 6 percent of all websites and 39 percent of cloud environments. When end users reload a page, React allows servers to re-render only parts that have changed, a feature that drastically speeds up performance and lowers the computing resources required by the server.*
>
> *Security firm Wiz said exploitation requires only a single HTTP request and had "near-100% reliability" in its testing. Multiple software frameworks and libraries embed React implementations by default. As a result, even when apps don't explicitly make use of React functionality, they can still be vulnerable, since the integration layer itself invokes the buggy code.*
>
> *The combination of the widespread use of React—particularly in cloud environments—the ease of exploitation, and the ability to execute code that gives attackers control of servers has earned the vulnerability a severity rating of 10, the highest score possible. On social media, security defenders and software engineers urged anyone responsible for React-related apps to immediately install an update released Wednesday.*
>
> *One researcher wrote: "I usually don't say this, but patch right freakin' now. The React CVE listing (CVE-2025-55182) is a perfect 10."*
>
> *React versions 19.0.1, 19.1.2, or 19.2.1 contain the vulnerable code. Third-party components known to be affected include: Vite RSC plugin, Parcel RSC plugin, React Router RSC preview, RedwoodSDK, Waku, Next.js. According to Wiz and fellow security firm Aikido, the vulnerability, tracked as CVE-2025-55182, resides in **Flight**, a protocol found in the React Server Components. Next.js has assigned the designation CVE-2025-66478 to track the vulnerability in its package.*

And then Dan hits us with the nature of the vulnerability which will also come as no surprise to

our longtime listeners since this podcast long ago identified "interpreters" as a particular problem for secure systems. Dan Writes:

> *The vulnerability stems from unsafe deserialization, the coding process of converting strings, byte streams, and other "serialized" formats into objects or data structures in code. Hackers can exploit the insecure deserialization using payloads that execute malicious code on the server. Patched React versions include stricter validation and hardened deserialization behavior.*
>
> *Wiz explained: "When a server receives a specially crafted, malformed payload, it fails to validate the structure correctly. This allows attacker-controlled data to influence server-side execution logic, resulting in the execution of privileged JavaScript code." They added: "In our experimentation, exploitation of this vulnerability had high fidelity, with a near 100% success rate and can be leveraged to a full remote code execution. The attack vector is unauthenticated and remote, requiring only a single specially crafted HTTP request to the target server. It affects the default configuration of many popular frameworks."*
>
> *Both companies are advising admins and developers to upgrade React and any dependencies that rely on it. Users of any of the Remote-enabled frameworks and plugins mentioned above should check with the maintainers for guidance. Aikido also suggests admins and developers scan their codebases and repositories for any use of React.*

Dan's article quickly generated 79 comments from which the Ars staff chose one, which reads:

> *Just ask Grok for a proof of concept 🤣 Basically the deserialiser can be made to execute any arbitrary code by encoding a nested object with an eval expression into base64 bytes. Shockingly easy to do.*

Okay. So now let's step back a bit to answer the question "What is React?" Wikipedia sums it up nicely, writing:

> *React (also known as React.js or ReactJS) is a free and open-source front-end JavaScript library that aims to make building user interfaces based on components more "seamless." It is maintained by Meta and a community of individual developers and companies. According to the Stack Overflow Developer Survey, React is one of the most commonly used web technologies.*
>
> *React can be used to develop single-page, mobile, or server-rendered applications with frameworks like Next.js and React Router. Because React is only concerned with the user interface and rendering components to the DOM, React applications often rely on libraries for routing and other client-side functionality. A key advantage of React is that it only re-renders those parts of the page that have changed, avoiding unnecessary re-rendering of unchanged DOM elements. React is used by an estimated 6% of all websites.*

Okay. Now we have some sense for what React is. So how widespread is its use? The platform security company "Ox" titled their reporting of this last Wednesday: *"Millions of servers vulnerable to RCE in React Components."* They wrote:

> *A critical vulnerability in React and Next.js allows attackers to execute code on vulnerable*

*servers without any authentication, potentially exposing millions of applications to immediate risk. React is one of the most popular JavaScript libraries for building user interfaces, created by Facebook (Meta), with over **1.97 billion** total downloads.*

Discovered today (Wednesday), this vulnerability affects the React and Next.js ecosystems, which power over 10 million active websites globally, including major platforms built with React such as Instagram, Netflix and Airbnb that serve billions of users daily.

With React downloaded over 20 million times weekly, new vulnerable applications are being deployed continuously. The potential exposure is massive – spanning e-commerce platforms, financial services, healthcare applications, and enterprise systems worldwide.

What we know: React (CVE-2025-55182) & Next.js (CVE-2025-66478) contain a critical RCE (Remote Code Execution) vulnerability, enabling the attacker to execute arbitrary, privileged JavaScript code on the vulnerable server. While the core issue stems from the React vulnerability, the Next.js vulnerability exists only because it directly used a vulnerable version of the React framework. The attack doesn't require any kind of authentication from the attacker or a valid running session for the RCE to work.

Who is affected? Any server running the unpatched version of React or Next.js, or any package based on a vulnerable React component. Using Shodan, we found that there are over 571,249 public servers using React components, and 444,043 using Next.js. While we don't know the versions of each of those servers, it would be safe to assume that even if a small number of them are inside the vulnerable versions range, the impact is on a high scale and should be addressed immediately.

Since this issue impacts any server online running React or Next.js, which are highly popular JavaScript based packages, this means that attackers could now scan and directly exploit those servers. This potentially could harm millions of servers around the world causing information leakage, secret extraction and more.

So, this is not good. Did anyone notice? Ha! You betcha! Two days later, last Friday December 5th, "Ox" followed up with their report of active exploitation under the headline *"React's CVE-2025-55182 Is Now Actively Exploitable: Verified PoC"* They wrote:

Hacker maple3142 published a working Proof of Concept for CVE-2025-55182 which we successfully verified. Just two days after we published our initial analysis of the React / Next.js server-side RCE vulnerability (CVE-2025-55182), a fully functional exploit has been released publicly. The PoC works exactly as expected and results in unauthenticated remote code execution on vulnerable servers.

*The exploit abuses React's $@ deserialization to forge a Chunk object and force execution of internal resolution logic on attacker-controlled data. By hijacking Blob deserialization so that **response._formData.get** points to the Function constructor, attacker-supplied code is returned and executed, resulting in full remote code execution on the server.*

They then get into the details of the attack and congratulate the exploit's author, maple3142 calling it great work. They also provide a link to maple's exploit demo documentation on Github: https://gist.github.com/maple3142/48bc9393f45e068cf8c90ab865c0f5f3

To no one's surprise, the industry has jumped to get this resolved and there were apparently a few hiccups along the way. Cloudflare notably suffered a 25-minute oopsie! outage while working to protect all of the servers behind them from the abuse of this vulnerability.

Network World reported under their headline: *"Cloudflare firewall reacts badly to React exploit mitigation"* with the subhead: *"In attempting to fix one problem, Cloudflare caused another."* They wrote:

> *Cloudflare's network suffered a brief but widespread outage Friday, after an update to its Web Application Firewall to mitigate a vulnerability in React Server Components went wrong. At 9:09 a.m. UTC, the company reported that it was investigating issues with the Cloudflare Dashboard and related APIs, warning that customers might see requests fail or errors displayed. Just 10 minutes later, it had deployed a fix — but not before a flood of reports of problems with Cloudflare and its customers poured into uptime tracking sites such as Downdetector.com. During the same window, Downdetector saw a spike in problem reports for enterprise services including Shopify, Zoom, Claude AI, and Amazon Web Services, and a host of consumer services from games to dating apps.*
>
> *Cloudflare explained the outage on its service status page: "A change made to how Cloudflare's Web Application Firewall parses requests caused Cloudflare's network to be unavailable for several minutes this morning. This was not an attack; the change was deployed by our team to help mitigate the industry-wide vulnerability disclosed this week in React Server Components."*
>
> *Cloudflare was no doubt attempting to protect those of its customers who have not yet had an opportunity to patch the vulnerability in the two days since it was revealed. The wobble in Cloudflare's services comes just two weeks after a much bigger one rendering its customers' websites inaccessible or unreliable for hours on Nov. 18. That was caused by one Cloudflare application generating a configuration file that was too big for another application to parse, bringing systems to a halt.*
>
> *This outsized impact of that small failure on websites around the world was reminiscent of a bug that hit AWS services the previous month. A coding error in its DNS systems led to a DynamoDB endpoint becoming inaccessible. That wouldn't have been so bad, but many other services used by AWS internally and by its customers relied on it, so they too were affected.*

I appreciated how these guys, Network World, concluded their note. They wrote:

> *There are some advantages in relying on single service providers such as Cloudflare or AWS for these tasks — including economies of scale and service consistency. But it also makes them single points of failure: when they go down, everything goes down with them. In such a monoculture, the alternatives that might be able to take up the slack have already been weeded out.*

I think that gets it exactly right. Cloudflare's own posting about this noted that their logs did not capture any evidence of successful exploitation of this vulnerability against any of their free or commercial customers by the time they had blocked it with their own Web Application Firewall. They never explicitly said that their apparently related service outage was a mistake, but it certainly seems likely. They are continually updating their Web Application Firewall with new detections and blocks and their customers are not experiencing system-wide outages.

AWS and Fastly also quickly deployed their own network protections for their customers.

I should also mention that two China-based threat actors were seen to immediately jump onto this exploit with attacks beginning within hours of the vulnerability's public disclosure. The AWS security team linked those attacks to two groups tracked as Earth Lamia and Jackpot Panda. AWS wrote:

- "Earth Lamia is a China-nexus cyber threat actor known for exploiting web application vulnerabilities to target organizations across Latin America, the Middle East, and Southeast Asia. The group has historically targeted sectors across financial services, logistics, retail, IT companies, universities, and government organizations."

- "Jackpot Panda is a China-nexus cyber threat actor primarily targeting entities in East and Southeast Asia. The activity likely aligns to collection priorities pertaining to domestic security and corruption concerns."

Amazon says the attackers used anonymizing proxies to hide their infrastructure and also deployed exploits for other vulnerabilities. Both groups used their own home-grown exploit implementations. This is not surprising since I'm sure they wanted to get going immediately and the exploitation of the vulnerability had very low complexity. It was dead simple to do. Later, multiple public proof-of-concept exploits were released, including one from Lachlan Davidson, the security researcher who initially found and reported the devastating vulnerability.

It's likely not an exaggeration to say that this vulnerability is likely to haunt the dev ecosystem for some time due to its ease of exploitation, widely available proofs of concept, its low complexity versus its power, as well as React's popularity. Next.js is currently considered to be the best web technology available for producing very SEO-friendly content. If a technology was ever expected to replace WordPress, it would be Next.js.

Palo Alto Networks wrote: "Ultimately, this incident underscores the inherent friction between performance and security in modern architecture. While React Server Components optimize data fetching and search engine optimization (SEO) by moving logic closer to the source, they simultaneously move the attack surface closer to organizations' most sensitive and valuable data."

I think that's a terrific perspective.